



CASE STUDY

Empowering a Fintech
Organization with
ISO/IEC
27001:2022

Executive Summary

In a bid to strengthen information security and win the trust of global financial partners, a leading India-based fintech organization partnered with InfosecTrain to implement ISO/IEC 27001:2022. Operating in the cloud SaaS space and handling sensitive financial data, the organization sought to enhance its compliance posture, protect customer data, and position itself as a secure, reliable fintech partner. InfosecTrain's step-by-step guidance led the organization to achieve certification within six months, enabling improved operational security, reduced incidents, and increased market opportunities.



The Client

The client is a fast-growing fintech company offering cloud-hosted digital wallets, payment gateway APIs, and financial services applications to global clients. Serving banks, insurance companies, and cross-border financial partners, the organization handles vast amounts of Personally Identifiable Information (PII), financial transaction data, and third-party integrations with banking APIs.

The Challenges

Fintech companies handle high volumes of PII, transaction data, and APIs with banks. With increasing regulatory pressure (e.g., RBI, GDPR, PCI-DSS), the client sought ISO/IEC 27001:2022 certification to

- Secure customer trust
- Align with global information security standards
- Win contracts with banks, insurance firms, and cross-border partners
- Reduce security incidents and support business continuity



Our Solution

InfosecTrain crafted a customized ISO/IEC 27001:2022 implementation roadmap tailored for the fintech sector. The approach included

Leadership Alignment

Engaged top management to define ISMS scope and assign responsibilities

Control Implementation

Integrated key controls for cloud security governance, secure coding, threat intelligence, and data privacy

Comprehensive Risk Management

Conducted detailed risk assessments and aligned mitigation plans with ISO 27001:2022 Annex A controls

Security Awareness

Delivered role-based training on phishing, secure development practices, and data privacy awareness

Audit Preparedness

Supported internal audits and management reviews, leading to a successful external certification audit

Policy & Documentation Development

Created policies such as Access Control, Incident Response, and Backup & Recovery, with change tracking through Confluence and Git

Step-by-Step ISO 27001:2022 Implementation Plan

Step 1: Top Management Commitment and Project Kickoff

- Appointed Chief Security Officer (CSO) as ISMS Manager
- Signed Information Security Policy
- Assigned roles to core departments: IT, Legal, DevOps, Risk, and Support

Tools Used



Project Plan
in Jira



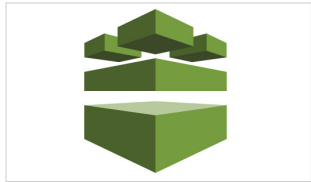
Kickoff deck via
Confluence

Step 2: Scope Definition & Asset Inventory

- Scoped ISMS for
 - » Cloud-hosted digital wallet
 - » Payment gateway APIs
 - » Web & mobile apps
 - » Internal DevOps pipeline
 - » Partner integrations (bank APIs)

- Created an Asset Register with physical and logical assets
 - » EC2 Instances, VPCs, GitHub Repos, SQL Databases, APIs

Tools Used



AWS Config



CMDB



Excel for
classification

Step 3: Risk Assessment and Risk Treatment

- Risk assessment using likelihood-impact matrix.
- Mapped each risk to ISO 27001:2022 Annex A controls.
- Documented Risk Treatment Plan with mitigation or acceptance logic.

Tools Used



Nessus



Excel Risk
Matrix



AWS
Inspector

Step 4: Implementing ISO 27001:2022 Controls

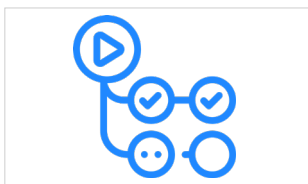
Key 2022 Controls Applied

- **A.5.23** – Cloud Security Governance
- **A.5.30** – Secure Coding Practices
- **A.5.7** – Threat Intelligence from FS-ISAC feeds
- **A.8.11** – Data Masking of card numbers
- **A.8.12** – Data Leakage Prevention (DLP) via CASB
- **A.5.10** – Acceptable Use of IS

Tools Used



AWS KMS



GitHub
Actions



SonarQube



Trend Micro
CASB

Step 5: Policies, Procedures, and Documentation

Created and version-controlled the following

- ISMS Policy
- Access Control Policy
- Source Code Management Policy
- Incident Response Plan
- Backup & Recovery Policy
- SoA (Statement of Applicability)
- Risk Register + Treatment Plan

Tools Used



Confluence



Git for change
tracking

Step 6: Security Awareness and Training

- Trained all 160+ employees on
 - » Phishing
 - » Secure coding (for devs)
 - » Password hygiene
 - » Responsible use of company assets

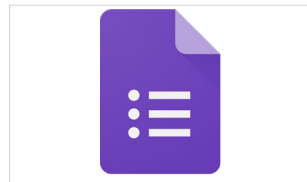
Tools Used



KnowBe4



Custom LMS



Google Forms
quizzes

Step 7: Internal Audit and Management Review

- Conducted internal audits using a tailored checklist.
- Identified and closed 5 minor NCRs.
- Held Management Review Meeting (MRM) to validate controls

Audit Scope: HR, Tech, Product, Customer Support

Tools Used



ISO audit checklist



Google Meet for MRM

Step 8: External Certification Audit

- Stage 1 (Readiness): Documentation review – passed
- Stage 2 (On-site & Cloud Validation)
 - » DevOps CI/CD pipeline security
 - » IAM & least privilege checks in AWS
 - » SOC alerts and response

Result: ISO/IEC 27001:2022 Certified with Zero Major NCs

Best Practices Followed

Tailored controls to fintech **threat landscape** (APIs, cloud, CI/CD)

Used **automated tools** to enforce and monitor compliance

Mapped ISO 27001 controls to regulatory expectations (RBI, PCI-DSS)

Not treated ISO as a checkbox— but embedded it into product delivery

Roadblocks Encountered

Cloud-native environments needed control mapping beyond standard checklists

Devs resisted secure coding gates initially

Integrating SoA into the sprint lifecycle was tricky

Solution: Weekly DevSecOps stand-ups and “Security Champion” model for teams

The Impact & Outcome



ISO/IEC 27001:2022 Certified

Achieved certification with zero major non-conformities



Reduced Phishing Incidents

Monthly phishing click rates dropped from 9% to 1.2% post-training



Faster Incident Response

Reduced average incident response time from 12 hours to 2 hours



Increased Business Wins

Improved contract win rates with regulated financial institutions from 30% to 65%



Automated Compliance

Shifted from manual processes to centralized, automated audit readiness



Improved Data Privacy

Enhanced data protection practices minimized data leakage incidents from 2 per year to zero reported cases

Outcomes and Measurable Results

Metric	Before ISO 27001	After ISO 27001
Monthly Phishing Clicks	9%	1.2%
Security Incident Response Time	12 hrs	2 hrs
Contract Win Rate (Banks)	30%	65%
Audit Readiness	Manual	Centralized + Automated
Data Leakage Incidents	2/year	0 reported



What the Client Says

“InfosecTrain’s expertise made our ISO 27001 journey smooth and impactful. Their practical approach, especially in aligning controls to our cloud-native fintech environment, helped us achieve certification on time. Beyond compliance, this initiative strengthened our market credibility and internal security culture.”

Chief Security Officer



Conclusion

InfosecTrain's comprehensive ISO/IEC 27001:2022 consulting along with a risk-based, scalable, and regulation-ready framework enabled the fintech company to transform security from a compliance requirement to a business enabler. By embedding security into product development and operations, the organization fortified its defenses, gained customer trust, and positioned itself for secure global expansion.



Future Plans

The client plans to

- Conduct quarterly risk assessments and ISMS reviews.
- Extend ISO-based security practices into DevSecOps and product development lifecycles.
- Leverage InfosecTrain for ongoing internal auditor training, compliance automation, and advanced security awareness programs





GET IN TOUCH

sales@infosectrain.com

www.infosectrain.com

